Analisis de Seguridad — Vault

chrome.storage.local cifrado | Phishing Shield

CRÍTICO 1. Fuerza bruta a la contrasena maestra

El atacante intenta millones de combinaciones offline

Vector de ataque
Si obtiene chrome.storage.local (SQLite en disco), puede intentar descifrar el vault sin limite de intentos — no hay servidor que lo bloquee.

Mitigacion
PBKDF2 con 600.000 iteraciones + salt unico hace cada intento ~200ms en CPU moderna. Contrasena de 12+ caracteres con variedad tarda siglos en romperse.

Estado
[!] Mitigado si la contrasena maestra es fuerte

Argumento tesis
El costo computacional de PBKDF2-HMAC-SHA256 con 600.000 iteraciones eleva el tiempo por intento a ~200ms, haciendo inviable el ataque de diccionario contra contrasenas de entropia moderada.

[PBKDF2] [Salt aleatorio] [600k iteraciones] [Sin limite offline]

CRÍTICO 2. Acceso fisico al equipo

Atacante con acceso al PC puede leer el storage de Chrome

Vector de ataque
chrome.storage.local esta en AppData/Local/Google/Chrome/User Data. Sin disco cifrado ni contrasena de sesion, cualquiera puede copiar ese SQLite.

Mitigacion
Responsabilidad del SO (BitLocker/FileVault). El vault agrega capa extra: sin la contrasena maestra el blob es ilegible aunque se robe el archivo.

Estado
[!] Mitigado por cifrado del vault; disco sin cifrar es riesgo del SO

Argumento tesis
El modelo de amenaza asume que el SO es el root of trust. La extension garantiza confidencialidad incluso si el storage es exfiltrado; la integridad del entorno del SO queda fuera del alcance del diseno.

[Fuera del scope de la extension] [BitLocker] [AES-256-GCM protege el blob]

CRÍTICO 3. Malware / extension maliciosa

Otro proceso en el equipo lee el DOM o la memoria

Vector de ataque
Un keylogger captura la contrasena maestra al escribirla. Malware con privilegios puede leer la memoria de Chrome y extraer el DEK o las contrasenas ya descifradas.

Mitigacion
Sin defensa completa a nivel extension contra malware con privilegios de SO. El DEK es CryptoKey no extractable. Tiempo de exposicion en memoria es minimo (auto-lock 15 min).

Estado
[X] Limitacion inherente de cualquier password manager local

Argumento tesis
Este vector existe en todos los gestores locales incluyendo KeePass, Bitwarden offline y 1Password. La mitigacion consiste en reducir la ventana de exposicion y no mantener el DEK en variables JS serializables.

[Keylogger] [Memoria de proceso] [CryptoKey no extractable] [Auto-lock 15 min]

ALTO 4. XSS en paginas web

Script malicioso intenta comunicarse con la extension

Vector de ataque
Un XSS en una pagina podria intentar llamar a chrome.runtime.sendMessage para solicitar credenciales al background SW.

Mitigacion
MV3 bloquea esto por diseno: el background SW solo responde a mensajes internos. externally_connectable no esta definido. vaultGetAutofill filtra por hostname exacto.

Estado
[OK] Mitigado por arquitectura MV3

Argumento tesis
Manifest V3 elimina el acceso directo de paginas web al background service worker. El content script actua como mediador con superficie de ataque controlada.

[MV3 sandbox] [externally_connectable no definido] [Filtro por hostname]

ALTO

5. Robo del blob cifrado (exfiltracion)

El blob AES-GCM es exfiltrado y atacado offline

Vector de ataque El atacante copia el SQLite de Chrome y extrae el JSON del vault. Intenta descifrar el blob sin la clave.

Mitigacion AES-256-GCM es autenticado: cualquier descifrado con clave incorrecta produce error de autenticacion. Sin la KEK es computacionalmente inviable.

Estado **[OK] Mitigado por AES-256-GCM + PBKDF2**

Argumento tesis *El cifrado autenticado garantiza confidencialidad e integridad. Un adversario con el ciphertext pero sin la contrasena maestra enfrenta un espacio de busqueda de 2^256 sin atajos conocidos.*

[AES-256-GCM] [Autenticado (AEAD)] [IV aleatorio por operacion] [Salt unico]

MEDIO

6. Manipulacion / rollback del storage

El atacante modifica o reemplaza el blob en disco

Vector de ataque El atacante reemplaza el blob cifrado por uno anterior (rollback) o lo corrompe para forzar comportamiento inesperado.

Mitigacion AES-GCM incluye tag de autenticacion de 128 bits: blob modificado falla verificacion. Rollback temporal no se detecta actualmente — mejora futura: contador de version firmado.

Estado **[!] Corrupcion detectada; rollback requiere mejora futura**

Argumento tesis *AEAD detecta modificacion pero no reordenamiento temporal. Mitigacion completa requeriria un nonce monotonamente creciente o timestamp firmado, identificado como mejora futura.*

[GCM auth tag 128-bit] [Rollback no detectado actualmente]

MEDIO

7. Phishing de la UI del vault

Pagina falsa imita la UI del vault para robar la master password

Vector de ataque El atacante crea una pagina que imita visualmente el popup del vault y solicita la contrasena maestra.

Mitigacion El vault popup carga desde chrome-extension:// (URL unica e infalsificable). TOTP invalida contrasena maestra robada sin el segundo factor.

Estado **[!] Inherente; la URL chrome-extension:// es la defensa principal**

Argumento tesis *La URL chrome-extension:// con el ID unico de la extension actua como autenticador de origen. Una pagina web no puede suplantar ese origen. TOTP invalida credenciales capturadas sin el segundo factor.*

[chrome-extension:// origin] [TOTP como segunda capa]

BAJO

8. Perdida de datos (disponibilidad)

Desinstalar Chrome o la extension borra el vault

Vector de ataque Desinstalar la extension, limpiar el storage o formatear destruye el vault sin recuperacion posible.

Mitigacion Se puede agregar export/import como archivo .json cifrado. La arquitectura local es intencional bajo Ley 21.719 — sin tercero que almacene datos.

Estado **[!] Riesgo de disponibilidad; mitigable con export cifrado**

Argumento tesis *El diseno prioriza confidencialidad sobre disponibilidad, alineado con la Ley 21.719. La exportacion cifrada es una mejora planificada.*

[Disponibilidad vs privacidad] [Export cifrado (mejora)] [Ley 21.719]

Postura general: El cifrado ocurre en el browser antes de persistir — nadie en la red ve texto plano. El unico acceso legitimo requiere la contrasena maestra que solo conoce el usuario. Los vectores reales de ataque requieren acceso fisico, malware instalado, o ingenieria social.